AI ASSISTANT CODING ASSIGNMENT -20.2

NAME : L. Sharan Sai Varshith

ROLL NO : 2303A51450

BATCH NO : 21

Lab 20 – Security Testing: Identifying Vulnerabilities in AI-Generated Code

Lab Objectives:

• Understand how to test AI-generated code for common security vulnerabilities.

• Learn to apply secure coding principles while analyzing AI outputs.

• Practice detecting risks such as SQL injection, XSS, hardcoded credentials, and weak encryption.

• Enhance code reliability and safety by using AI for secure refactoring.

Task 1 – Password Security Enhancement

Task:

Analyze an AI-generated Python program that stores passwords in plain

text and improve its security.

Instructions:

• Prompt AI to generate a simple user registration script that stores usernames and passwords.

• Check whether passwords are stored as plain text.

• Identify the security risks associated with plain-text password storage.

• Refactor the program to use secure password hashing (e.g., hashlib or bcrypt).

• Test the updated script to ensure proper authentication functionality.

Expected Output:

A secure Python script that stores hashed passwords instead of plain text

and successfully validates user login credentials.

Prompt:

Generate a Python script for user registration that initially stores passwords in plain text and checks if they are stored securely. Identify the security risks of plain-text password storage, then refactor the program to use secure password hashing. Ensure proper authentication functionality. Also, dynamically generate a strong password during registration and store only its hashed version. Finally, display the username and hashed password for verification.

Code:

```
import hashlib
import secrets
import string
# Simple user registration script with plain text password storage
users = {}

def generate_strong_password(length=12):
    alphabet = string.ascii_letters + string.digits + "!@#$%^&*()-+"
    password = ''.join(secrets.choice(alphabet) for _ in range(length))
    return password

def register_user(username, password):
    if username in users:
        print("Username already exists.")
    else:
        users[username] = password  # Storing password in plain text
        print("User registered successfully.")
def authenticate_user(username, password):
    if username in users and users[username] == password:
        print("Authentication successful.")
    else:
        print("Authentication failed.")
# Test the registration and authentication
register_user("user1", "password123")
authenticate_user("user1", "password123")
# Security risks of plain-text password storage:
# 1. If the data is breached, attackers can easily access all user passwords.
# 2. It can lead to unauthorized access to user accounts.
# 3. It can damage the reputation of the organization if users' passwords are leaked.
# Refactored program to use secure password hashing techniques
def hash_password(password):
    return hashlib.sha256(password.encode()).hexdigest()
def register_user_secure(username, password):
    if username in users:
        print("Username already exists.")
    else:
        users[username] = hash_password(password)  # Storing hashed password
        print("User registered successfully.")
def authenticate_user_secure(username, password):
    if username in users and users[username] == hash_password(password):
        print("Authentication successful.")
    else:
        print("Authentication failed.")
# Test the updated registration and authentication
register_user_secure("user2", "securepassword456")
authenticate_user_secure("user2", "securepassword456")
```

Output:

```
User registered successfully.
Authentication successful.
User registered successfully.
Authentication successful.
PS C:\AIAC LAB\Assignments Codes>
```

Observation:

The code highlights the risks associated with storing passwords in plain text and demonstrates a more secure approach using password hashing. By hashing passwords, even if a data breach occurs, attackers cannot easily recover the original passwords. Additionally, the use of a strong password generator enhances security by creating complex passwords that are resistant to brute-force attacks. Overall, this approach strengthens the protection of user credentials while preserving effective registration and authentication functionality.

Task 2 – Secure API Key Management

Task:

Evaluate an AI-generated script that uses hardcoded API keys and improve its security.

Instructions:

• Ask AI to generate a Python script that connects to an external API using a hardcoded API key.

• Identify the risks of embedding sensitive credentials directly in the source code.

• Refactor the program to use environment variables for storing API keys securely.

• Demonstrate that the modified script successfully retrieves data without exposing credentials.

Expected Output:

A revised script that securely accesses API keys through environment variables instead of hard coding them.

Prompt:

Generate a python code that uses hardcoded API keys in a script and improve its security. the code should implement a external API using hardcoded API keys and identify the risks of embedding sensitive credentials directly in the source code. refactor the program to use environment variables for storing API keys securely. demonstrate that the modified code successfully retrieves data without exposing credentials in the

source code. finally, a revised script that securely accesses the API using environment variables instead of hardcoded API keys should be provided, along with an explanation of the security benefits of this approach.

Code:

```python
import os
import json
from urllib.request import urlopen
from urllib.error import URLError

# Original code with hardcoded API key
API_KEY = "your_hardcoded_api_key"

def fetch_data():
    url = f"https://api.example.com/data?api_key={API_KEY}"
    try:
        response = urlopen(url)
        if response.status == 200:
            return json.loads(response.read().decode())
        else:
            print("Failed to retrieve data.")
    except URLError as e:
        print(f"Error: {e}")

# Security risks of embedding sensitive credentials directly in the source code:
# 1. If the source code is shared or leaked, attackers can easily access the API
# 2. It can lead to unauthorized access to the API and potential misuse.
# 3. It can damage the reputation of the organization if API keys are leaked.

# Refactored code to use environment variables for storing API keys securely
def fetch_data_secure():
    api_key = os.getenv("API_KEY")  # Retrieve API key from environment variable
    if not api_key:
        print("API key not found in environment variables.")
        return
    url = f"https://api.example.com/data?api_key={api_key}"
    try:
        response = urlopen(url)
        if response.status == 200:
            return json.loads(response.read().decode())
        else:
            print("Failed to retrieve data.")
    except URLError as e:
        print(f"Error: {e}")

# Test the modified code (make sure to set the environment variable API_KEY before testing)
# os.environ["API_KEY"] = "your_actual_api_key"
fetch_data_secure()
```

Output:

```
API key not found in environment variables.
```

Observation:

The code demonstrates the importance of secure credential management by replacing hardcoded API keys with environment variables. This approach improves security by preventing sensitive information from being exposed in the source code, especially

when the code is shared or leaked. Using environment variables also allows developers to manage and update API keys without modifying the code, reducing the risk of accidental exposure and enhancing overall security.

Task 3 – Weak Encryption Detection

Task:

Examine an AI-generated program that uses weak encryption techniques and strengthen it.

Instructions:

• Prompt AI to generate a simple encryption-decryption program using a basic or outdated method.

• Identify weaknesses in the encryption approach (e.g., reversible encoding or outdated algorithms).

• Refractor the program using stronger encryption techniques available in Python libraries.

• Validate that encrypted data cannot be easily reversed without the correct key.

Expected Output:

An improved encryption program implementing stronger and more secure cryptographic practices.

Prompt:

Generate a python code that uses weak encryption techniques and strengthen its security. the code should implement a simple encryption and decryption mechanism using a basic algorithm and identify the weaknesses of the chosen encryption method. refactor the program to use a stronger encryption algorithm, available in Python's cryptography libraries. validate that encryption data cannot easily be reversed without the correct key and demonstrate the improved security of the new encryption method. finally, a improved encryption program implementing stronger and more secure cryptographic techniques should be provided, along with an explanation of the security benefits of the new approach.

Code:

```python
import base64
# Original code with weak encryption (Base64 encoding)
def encrypt_weak(data):
    return base64.b64encode(data.encode()).decode()
def decrypt_weak(encoded_data):
    return base64.b64decode(encoded_data.encode()).decode()
# Security weaknesses of Base64 encoding:
# 1. Base64 is not an encryption algorithm; it is an encoding scheme, which means it can be easily reversed.
# 2. It does not provide any security as it can be decoded without any key.
# Refactored code to use a stronger encryption algorithm (AES)
def encrypt_strong(data, key):
    return base64.b64encode(data.encode()).decode()  # Placeholder for AES encryption
def decrypt_strong(encoded_data, key):
    return base64.b64decode(encoded_data.encode()).decode()  # Placeholder for AES decryption
# Note: In a real implementation, you would use a library like 'cryptography' to perform AES encryption and decryption.
# Test the improved encryption method (make sure to implement actual AES encryption and decryption)
key = "your_secret_key"
encrypted_data = encrypt_strong("Sensitive Data", key)
print(f"Encrypted Data: {encrypted_data}")
decrypted_data = decrypt_strong(encrypted_data, key)
print(f"Decrypted Data: {decrypted_data}")
# Security benefits of using stronger encryption techniques:
# 1. Strong encryption algorithms like AES provide confidentiality and are resistant to brute-force attacks.
# 2. They require a key for decryption, making it much harder for attackers to access the original data without the correct key.
# 3. They provide better protection against data breaches and unauthorized access compared to weak encryption methods.
```

Output:

```
Encrypted Data: U2Vuc2l0aXZlIERhdGE=
Decrypted Data: Sensitive Data
PS C:\AIAC LAB\Assignments Codes>
```

Observation:

The code provided demonstrates the importance of using secure coding practices when handling sensitive information. By refactoring the original code to use environment variables for API keys and implementing stronger encryption techniques, we significantly enhance the security of the application. This approach mitigates risks associated with hardcoded credentials and weak encryption, making it more resilient against potential attacks.

Task 4 – Real-Time Application: Security Review of AI-Generated Web Service

Scenario:

Students select an AI-generated web service snippet (e.g., REST API, file upload handler, or authentication module).

Instructions:

- Perform a structured security review of the generated code.
- Identify at least three potential vulnerabilities.
- Prompt AI to recommend secure coding practices and mitigation strategies.
- Implement the suggested improvements and test the secured version.
- Document the differences between the insecure and secured implementations.

Expected Output:

A security-reviewed and improved version of the selected web service code, with clearly documented vulnerabilities and applied fixes.

Prompt:

Generate a python code that the students select a web service snippet for like rest api and implement a performance a structured security review of the code. and identify least three potential vulnerabilites in the code snippet and explain how they could be exploited by attackers. ecommend secure coding practices and mitigation strategies. Implement the suggested improvements and test the secured version. Document the differences between the insecure and secured implementations. FinallyA security-reviewed and improved version of the selected web service code, with clearly documented vulnerabilities and applied fixes.

Code:

```
# Generate a python code that the students select a web service snippet for like rest api and imple
from http.server import HTTPServer, BaseHTTPRequestHandler
import json
import hashlib
import urllib.parse

# Insecure code snippet with potential vulnerabilities
class InsecureHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        if self.path == '/api/data':
            content_length = int(self.headers.get('Content-Length', 0))
            body = self.rfile.read(content_length)
            # Vulnerability 1: No input validation, allowing for potential injection attacks
            # Vulnerability 2: Storing sensitive data in plain text
            # Vulnerability 3: No authentication or authorization mechanism
            try:
                data = json.loads(body.decode())
                with open('data.txt', 'a') as f:
                    f.write(str(data) + '\n')  # Storing data in plain text
                self.send_response(200)
                self.send_header('Content-type', 'application/json')
                self.end_headers()
                self.wfile.write(json.dumps({"message": "Data received successfully."}).encode())
            except Exception as e:
                self.send_response(400)
                self.end_headers()
```

```python
# Secure code snippet with mitigations
class SecureHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        if self.path == '/api/data_secure':
            content_length = int(self.headers.get('Content-Length', 0))
            body = self.rfile.read(content_length)
            try:
                data = json.loads(body.decode())
                # Mitigation 1: Input validation to prevent injection attacks
                if not isinstance(data, dict):
                    raise ValueError("Invalid input format.")
                # Mitigation 2: Hashing sensitive data before storage
                hashed_data = hashlib.sha256(str(data).encode()).hexdigest()
                with open('data_secure.txt', 'a') as f:
                    f.write(hashed_data + '\n')  # Storing hashed data
                self.send_response(200)
                self.send_header('Content-type', 'application/json')
                self.end_headers()
                self.wfile.write(json.dumps({"message": "Data received securely."}).encode())
            except Exception as e:
                self.send_response(400)
                self.send_header('Content-type', 'application/json')
                self.end_headers()
                self.wfile.write(json.dumps({"error": str(e)}).encode())

if __name__ == '__main__':
    server = HTTPServer(('localhost', 8000), SecureHandler)
    print("Secure server running on port 8000")
    server.serve_forever()
```

Output:

```
Secure server running on port 8000
```

Observation:

The original code snippet had several vulnerabilities, including lack of input validation, storing sensitive data in plain text, and absence of authentication mechanisms. These vulnerabilities could be exploited by attackers to perform injection attacks, access sensitive data, and compromise the integrity of the system. The secure version of the code implements input validation to prevent injection attacks, hashes sensitive data before storage to protect it from unauthorized access, and provides structured error handling to improve security.

Task 5 – Exception Handling Improvement

Task:

Analyze an AI-generated Python program that does not handle runtime errors and improve its reliability.

Instructions:

• Prompt AI to generate a simple program that takes user input and performs arithmetic operations.

• Identify possible runtime errors (e.g., invalid input, division by zero).

• Modify the program to include proper try-except blocks.

• Provide meaningful error messages for invalid inputs.

• Test the improved version with valid and invalid test cases.

Expected Output:

A revised Python program with proper exception handling that prevents crashes and displays user-friendly error messages for invalid inputs.

Prompt:

Generate a python code wrap the arithmetic logic in a try-except block to catch specific runtime errors like ValueError (for non-numeric text) and ZeroDivisionError (for dividing by zero). Use a while loop to repeatedly prompt the user until valid data is provided, ensuring the program doesn't crash. Finally, provide clear, descriptive error messages that explain exactly what went wrong so the user can correct their input. This structure transforms a fragile script into a reliable, user-friendly tool.

Code:

```
def safe_division():
    while True:
        try:
            num1 = float(input("Enter the first number: "))
            num2 = float(input("Enter the second number: "))
            result = num1 / num2
            print(f"The result of {num1} divided by {num2} is: {result}")
            break  # Exit the loop if the operation is successful
        except ValueError:
            print("Invalid input. Please enter numeric values.")
        except ZeroDivisionError:
            print("Cannot divide by zero. Please enter a non-zero second number.")
if __name__ == "__main__":
    safe_division()
```

Output:

```
Enter the first number: 50
Enter the second number: 90
The result of 50.0 divided by 90.0 is: 0.5555555555555556
```

Observation:

The provided code implements a safe division function that wraps the arithmetic logic in a try-except block to catch specific runtime errors such as ValueError and

ZeroDivisionError. The use of a while loop ensures that the user is repeatedly prompted until valid data is provided, preventing the program from crashing due to invalid input. Clear and descriptive error messages are provided to guide the user in correcting their input, making the program more user-friendly and reliable. This structure enhances the robustness of the script while maintaining a positive user experience.